

GenAI Threat Matrix for Healthcare SOCs

Author: Kim Lien Chu – Healthcare Cybersecurity Analyst

Theme: Adversary Technique Mapping, SQL Detection Signals, and Clinical Risk Prioritization

Visual Mapping of Adversarial Techniques, SQL Detection Signals, and Sector Impact

Threat Type	MITRE ATT&CK Mapping	SQL Detection Signal	Healthcare Impact
Prompt Injection	T1059 – Command and Scripting Interpreter	SELECT * FROM access_logs WHERE process_name = 'AIApp.exe' AND command_line LIKE '%sudo%';	PHI leakage, unauthorized access
Indirect Injection	T1203 – Exploitation for Client Execution	SELECT * FROM file_events WHERE file_path LIKE '%lab_reports%' AND ai_model = 'GPT-4';	Model misbehavior, data poisoning
SSRF via Plugins	T1041 – Exfiltration Over C2 Channel	SELECT * FROM outbound_requests WHERE ip_address LIKE '10.%';	Cloud pivoting, lateral movement
LLM-Generated Exploits	T1587.001 – Malware Development	SELECT * FROM script_logs WHERE script_name = 'exploit.py' AND ai_generated = TRUE;	Accelerated exploit cycles
External API Abuse	T1190 – Exploit Public-Facing Application	SELECT * FROM plugin_calls WHERE response_code = '200' AND auth_method = 'none';	Unauthorized data access

ATT&CK Mapping + SQL Detection + Mitigation & Governance

1. Prompt Injection

MITRE ATT&CK: T1059 – Command and Scripting Interpreter

SQL Detection:

```
Sql Copy  
  
SELECT * FROM access_logs  
WHERE process_name = 'AIApp.exe'  
AND command_line LIKE '%sudo%';
```

Mitigation:

- Apply input sanitization and prompt filtering
- Restrict AI model access to sensitive commands

Governance Overlay:

- **HHS 405(d): Data Protection + Insider Threats**
 - Enforce PHI minimization
 - Train staff on GenAI input hygiene
-

2. Indirect Injection

MITRE ATT&CK: T1203 – Exploitation for Client Execution

SQL Detection:

```
Sql Copy  
  
SELECT * FROM file_events  
WHERE file_path LIKE '%lab_reports%'  
AND ai_model = 'GPT-4';
```

Mitigation:

- Scan external content for hidden prompts
- Isolate AI model access from unverified sources

Governance Overlay:

- **HHS 405(d): Asset Management + Cyber Hygiene**
 - Treat GenAI endpoints as privileged assets
 - Disseminate AI-specific hygiene training
-

3. SSRF via Plugins

MITRE ATT&CK: T1041 – Exfiltration Over C2 Channel

SQL Detection:

Sql

 Copy

```
SELECT * FROM outbound_requests  
WHERE ip_address LIKE '10.%';
```

Mitigation:

- Enforce plugin sandboxing
- Whitelist internal service endpoints

Governance Overlay:

- **HHS 405(d): Cloud Security**
 - Monitor plugin behavior
 - Restrict outbound traffic from GenAI tools
-

4. LLM-Generated Exploits

MITRE ATT&CK: T1587.001 – Malware Development

SQL Detection:

Sql

 Copy

```
SELECT * FROM script_logs
WHERE script_name = 'exploit.py'
AND ai_generated = TRUE;
```

Mitigation:

- Flag and review AI-generated scripts
- Apply model alignment and output filtering

Governance Overlay:

- **HHS 405(d): Cyber Hygiene + Data Protection**
 - Educate SOC teams on GenAI misuse
 - Validate AI-generated code before deployment

5. External API Abuse

MITRE ATT&CK: T1190 – Exploit Public-Facing Application

SQL Detection:

Sql

 Copy

```
SELECT * FROM plugin_calls
WHERE response_code = '200'
AND auth_method = 'none';
```

Mitigation:

- Require authentication for all plugin/API calls
- Monitor plugin access patterns

Governance Overlay:

- **HHS 405(d): Cloud Security + Insider Threats**

- Audit plugin configurations
- Train staff on secure plugin usage

SQL Field Reference Table for GenAI Threat Detection

- This table maps GenAI threats to SQL detection logic and healthcare impact. Each query is aligned with MITRE ATT&CK and governance overlays.

Field Name	Table	Purpose	Log Source	Data Retention Policy
process_name	access_logs	Identifies the executable or application invoked (e.g., AIApp.exe)	Application audit logs	Retain 90–180 days for forensic traceability
command_line	access_logs	Captures full command-line arguments used during execution	OS-level command audit	Retain 90 days minimum; extend for privileged access
file_path	file_events	Tracks file access or modification events (e.g., lab_reports)	EHR system logs / DLP sensors	Retain 180–365 days for PHI access auditing
ai_model	file_events	Specifies which AI model interacted with the file (e.g., GPT-4)	GenAI model interaction logs	Retain 90 days; extend if PHI or clinical data involved

ip_address	outbound_requests	Logs destination IPs for outbound traffic — useful for SSRF detection	Network proxy / firewall logs	Retain 30–90 days; extend for plugin or cloud traffic
script_name	script_logs	Identifies script files executed or generated (e.g., exploit.py)	AI development / runtime logs	Retain 90–180 days; longer if flagged as malicious
ai_generated	script_logs	Boolean flag indicating whether the script was AI-generated (TRUE/FALSE)	GenAI output logs	Retain 90 days; extend for exploit or anomaly correlation
response_code	plugin_calls	HTTP response status from plugin/API calls (e.g., 200)	Plugin gateway / API logs	Retain 30–90 days; extend for unauthorized access attempts
auth_method	plugin_calls	Authentication type used in plugin/API call (e.g., none, OAuth)	IAM logs / plugin telemetry	Retain 90–180 days; longer for failed or missing auth

References

1. [MITRE ATT&CK Sub-technique T1588.007 – AI Capabilities](#)
 2. [CISA Best Practices for MITRE ATT&CK Mapping \(2023\)](#)
 3. [CrowdStrike 2025 Threat Hunting Report](#)
-